ITBP481: Senior Graduation Project II

Final Project Report

Spring 2026

Integrated Risk Intelligence System (IRIS)

Project ID: 3

Ahmed Aref Alsehhi	202110388	Information Security
Taher Mousa	700041185	Information Security
Abdulla Alattas	202102869	Information Security
Abdulrahman Bin Braik	700042473	Information Security
Abdulaziz Al Rabeei	700042076	Information Security

Project Advisor: Prof. Ezedin Baraka

A project report submitted in partial fulfillment of the requirements for the Bachelor of Science degree at the College of Information Technology, United Arab Emirates University

27 October 2026

Evidence-based technical draft. The template semester is retained; the team must confirm the submission semester and approve contribution entries.

Executive Summary

IRIS addresses the separation between Security Operations Centre (SOC) alert handling and Governance, Risk and Compliance (GRC) risk assessment. SGP1 established the problem, requirements and conceptual architecture. SGP2 implements a reproducible three-source integration pipeline, two supervised advisory models, an explicit risk policy, and an approval-gated demonstration with persistent working records.

The operational inputs are an asset inventory, a risk register and SIEM alerts. Context is combined into unified event records before session feature engineering. The implementation validates identity, timestamps and historical context, removes duplicates and quarantines unresolved or conflicting records rather than guessing their meaning. A separate offline annotation file is used for training only; it is not a fourth operational input.

Model 1 is a calibrated random-forest scenario classifier. On the saved 135-session synthetic campaign holdout, accuracy is 94.07%, macro-F1 is 0.9405 and prediction coverage is 100%. However, seven of 45 benign sessions are classified as attacks, giving a 15.56% benign false-positive rate against an engineering limit of 5%. Therefore, the model is not released for operational decision-making. Model 2 uses binary-relevance logistic regression for control recommendations. Its micro-F1 is 0.9542, but only six of 30 catalogue controls have positive test support. Neither figure establishes effectiveness on an organization's live data.

The active demonstration runs locally with synthetic working systems. It generates 132 cases from 2,367 source alert rows, with 2,355 matched unique working alerts. Analysis creates proposals without changing risk or priority values. GRC approval changes one example risk from 0.60 to 0.80 by increasing likelihood from three to four while impact remains five. SOC approval changes 19 alerts to Critical, preserving ten already-Critical alerts in the same session. SQLite transactions, revision checks, audit records, exports and restart tests establish that these are backend changes, not cosmetic table edits.

The verified evidence comprises 177 Python regressions and 20 frontend-controller scenarios. Real loopback HTTP tests cover approval writes and concurrent activity monitoring. No browser-render study, two-second latency benchmark, production deployment or live vendor connector is claimed. Compared with SGP1, the project achieves a stronger executable local approval demonstration but a narrower external-integration scope. Its main contribution is an accountable bridge from security evidence to reviewable business-risk changes, with clear separation between experimental ML advice, explicit policy and human authority.

Contents

Executive Summary **i**

List of Tables **iv**

List of Figures **v**

1 Introduction **1**

1.1 Problem Statement 1

1.2 Objectives 1

1.3 Final Outcomes and Deliverables 2

1.4 Motivation and Relevance 2

1.5 Report Structure Summary 3

2 Professional Standards and Practice Constraints **4**

2.1 Economic Constraints 4

2.2 Environmental Constraints 4

2.3 Health, Safety, and Security 5

2.4 Social, Cultural, and Political Constraints 6

2.5 Ethical and Legal Compliance 6

3 System Design and Integration **7**

3.1 System Modules, Components, and Setup 7

3.1.1 Exactly Three Operational Inputs 8

3.1.2 Integration Before Analytical Cleaning and Features 8

3.1.3 Session Construction and Feature Contract 9

3.1.4 Model 1: Supervised Scenario Classification 9

3.1.5 Partitioning and Leakage Control 11

3.1.6 Model 2: Supervised Multi-label Control Advice 12

3.2 Technologies and Standards Applied 12
3.3 Challenges and Solutions 13

4 Implementation, Testing, and Results Analysis 15
4.1 Implementation Summary 15
4.1.1 Approval State and Active Writeback 15
4.2 Testing Strategy and Process 16
4.2.1 Metric Definitions 17
4.3 Results and Analysis 17
4.3.1 Dataset Provenance and Cleaning Results 17
4.3.2 Model 1: Held-out Performance 18
4.3.3 Model Selection and Comparison with Primary Rules 19
4.3.4 Threshold Selection and Release Decision 20
4.3.5 Model 2: Control-Recommendation Results 21
4.3.6 Active Demonstration and Before/After Results 22
4.3.7 Interface Failures, Corrections and Observability 23
4.4 Potential Improvements 24

5 Project Management and Teamwork Reflection 25
5.1 Tasks And Schedule Gantt Chart 25
5.2 Resources used During the Project 26

6 Conclusion and Future Recommendations 27

7 Statement of Contribution 28

References 29

A Reproducibility and Evidence Register 30

B Submission Confirmation Checklist 31

List of Tables

1 Objectives and their measurable verification evidence 2

2 Resource and feasibility constraints 5

3 Safety decisions and their assurance boundary 6

4 Operational input contracts and their roles 8

5 Model 1's complete allowlisted feature set 9

6 Training implementation configuration for reproducibility 10

7 Actual technologies and deployment boundaries 13

8 SGP1-to-SGP2 requirement and design traceability 14

9 Executed verification suites and their evidential meaning 16

10 Training and examiner-demonstration corpus sizes 17

11 Active demonstration alert-row accounting 18

12 Model 1 class-wise results on 135 held-out synthetic sessions 18

13 Recorded selection-partition candidate macro-F1 scores 19

14 Model 1 and frozen-rule test results with common metric definitions 19

15 Model 1 release-gate assessment 21

16 Model 2 held-out synthetic label-agreement metrics 21

17 Controls with positive held-out support 22

18 Persistent changes after owning-team approval 23

19 Observed interface problems and regression coverage 24

20 Documented SGP1 responsibility and SGP2 confirmation status 26

21 SGP2 task contribution percentages awaiting team confirmation 28

22 Student identification and signatures 28

23 Primary project evidence used in this report 30

List of Figures

1 Implemented local architecture; external SIEM/GRC vendor systems are not connected. 7

2 Separate primary-policy authority and two experimental learning tasks. The figure is a conceptual view of the implemented paths, not a benchmark plot. 11

3 Recorded campaign-disjoint partition sizes. The final test contains 45 sessions per class. 11

4 Recorded confusion matrices. Rows are true classes; columns are predictions. The baseline abstains on 33 sessions. 19

5 Coverage and error trade-offs on the same synthetic test set. A higher false-positive rate is worse. 20

6 Saved threshold-partition search; the final test remains held out. 20

7 Supported-control F1 and catalogue coverage. High micro-F1 does not establish coverage of all controls. 22

8 Deterministic policy-and-approval demonstration on fictional working records; these are not ML accuracy results. 23

9 Proposed relative work sequence for planning/reconciliation; bars are not historical completion evidence. 25

Chapter 1

Introduction

The SGP1 report describes a gap between technical security monitoring and business-risk understanding, and proposes an integrated system connecting SOC, SIEM and GRC information (Alsehhi et al., 2026). The present report examines the executable implementation rather than treating that proposal as a completed deployment. Throughout the report, *implemented* means supported by inspected source or recorded test evidence; *demonstrated* means exercised on synthetic records; and *proposed* means not established by the available implementation evidence.

1.1 Problem Statement

A technically severe alert does not, by itself, identify the relevant business asset, registered risk, risk owner or justified register update. Conversely, a risk register can retain an assessment that has not been reconsidered after new technical evidence. When these records are handled separately, analysts and risk officers must manually reconcile identities, severity, criticality and decision history. The core engineering problem is therefore not merely detecting an attack: it is preserving a defensible relationship between observed events, asset context, registered risks and approved updates.

IRIS addresses this problem within an explicitly limited local prototype. It cannot establish that commercial SIEM or GRC systems universally lack such functions. Instead, it demonstrates a concrete integration contract for the project's three input sources and a human-reviewed update workflow. The system does not infer asset identity from an attacker's source address or automatically overwrite a risk assessment using an ML probability.

1.2 Objectives

The objectives are to integrate the three datasets before analytical feature construction; classify bounded activity sessions; recommend relevant controls without equating recommendation scores with control effectiveness; create traceable risk and alert-priority propos-

als; and demonstrate persistent changes after separate owning-team approval. Evaluation must distinguish software correctness from statistical generalization. Table 1 connects these objectives to observable evidence.

Table 1: Objectives and their measurable verification evidence

ID	Objective	Evidence
O1	Combine three sources with consistent identities and time context.	Shared preparation function, exclusions and point-in-time tests.
O2	Provide supervised scenario and control advice.	Saved model metadata, holdout metrics and release gates.
O3	Connect evidence to business risk without silent changes.	Saved proposals; analysis-only tests show unchanged working values.
O4	Apply approved changes visibly and persistently.	Real HTTP approvals, exports, revision and restart tests.
O5	Keep authority and visibility role-specific.	Admin/SOC/GRC endpoint, HTML and controller checks.
O6	State limitations and support reproducibility.	Source hashes, grouped split manifest and regression suites.

1.3 Final Outcomes and Deliverables

The delivered prototype contains a Python three-source preparation and model package, linked synthetic training samples, the supplied Colab-trained model bundle, a Colab notebook, a shared policy/backend core, an active local HTTP demonstration, three role-specific views and reproducibility documentation. The working systems are synthetic SQLite records, not external company systems. The active demonstration uses Python's standard-library HTTP server; the separately prepared FastAPI adapter is not the service used for the examiner workflow.

The active demo adds an Admin-only read-only backend activity window. This records command starts, outcomes, durations and safe numeric response fields. It is not a terminal or a fabricated animation of individual ML steps. The source files, models and inputs remain separate from the mutable working register and queue.

1.4 Motivation and Relevance

The motivation remains consistent with SGP1: SOC analysts need operational evidence, GRC staff need interpretable business-risk context, and administrators need a complete audit view. IRIS makes these responsibilities visible through separate approval authority and information scopes. The value demonstrated is traceability and controlled integration, rather than a measured reduction in organizational incident costs or analyst workload. Those broader benefits require prospective studies with authorized users and representative records.

1.5 Report Structure Summary

Chapter 2 evaluates standards and practical constraints. Chapter 3 explains the implemented architecture, source integration and both model pipelines. Chapter 4 defines the experiments, metrics and results, including failures and release restrictions. Chapter 5 reflects on project management and distinguishes documented SGP1 responsibilities from unverified SGP2 allocations. Chapter 6 concludes with prioritized recommendations. Chapter 7 provides the contribution and signature structure for team confirmation. The appendices record reproducibility details and a submission checklist.

Chapter 2

Professional Standards and Practice Constraints

Engineering choices were constrained by limited representative data, a student-project budget and the need to demonstrate changes safely. The report uses external standards as design guidance, not as evidence that the prototype is certified. NIST CSF 2.0 provides an organizational risk-management reference; IRIS implements only a small workflow relevant to relating detection evidence to governance review (National Institute of Standards and Technology, 2024). It does not implement the complete framework.

2.1 Economic Constraints

The verified implementation uses Python, pandas, NumPy, scikit-learn, joblib and SQLite, with a local HTML/CSS/JavaScript interface. These choices avoid a mandatory commercial software subscription or dedicated GPU for this prototype. However, this is a description of the software stack, not a complete licensing audit or a measured total-cost-of-ownership calculation. No defensible monetary budget can be reconstructed from the available purchase or labor records.

SGP1 proposed Wazuh, Elasticsearch, virtual machines and Streamlit. Wazuh, Suricata and GNS3 should not be listed as verified dependencies of the active IRIS demo merely because they were discussed as possible collection environments. Real collection would introduce sensor provisioning, storage, security review and maintenance costs. The dominant present constraint is data preparation and validation: obtaining authorized attack and benign runs, historical asset/risk context and independently reviewed control labels requires more effort than writing a classifier wrapper.

2.2 Environmental Constraints

The prototype can run on CPU hardware and reuse recorded inputs. This avoids a requirement for continuous GPU training or an always-running cyber range during an

examination. Nevertheless, no electricity, carbon or lifecycle assessment was performed. CPU-only execution should therefore be described as a resource-conscious design decision, not a quantified environmental benefit.

Repeated training can be limited by retaining versioned models and reusing immutable evidence. Live deployment would require retention limits and storage monitoring because log growth, snapshots and model provenance can become substantial. Table 2 summarizes these constraints, not measured ownership costs.

Table 2: Resource and feasibility constraints

Resource	**Present evidence**	**Unmeasured or future cost**
Compute	CPU-based Python workflow; no GPU required.	Throughput and capacity under realistic concurrency.
Data	Linked synthetic inputs and offline annotations.	Authorized collection, privacy review and expert labeling.
Storage	Local SQLite, input snapshots and trusted artifacts.	Retention, backups, encryption and disaster recovery.
People	Five students and an advisor identified in SGP1.	Actual SGP2 hours and contribution weights need confirmation.

2.3 Health, Safety, and Security

The active workflow changes synthetic records only. It does not isolate hosts, disable accounts, install controls or execute an attack. The use of fictional assets reduces exposure to operational disruption and personal data, but synthetic testing cannot substitute for a later security assessment. Controls that could affect a real organization must remain outside this demonstration until separately authorized and reviewed.

The HTTP service binds to IPv4 loopback. It checks the local Host and browser origin, authenticates API calls using distinct configured role keys and validates bounded JSON commands. Keys are held in tab memory rather than URLs or browser storage. These are lab safeguards, not enterprise authentication: there is no claim of SSO, individual identity attribution, HTTPS transport or encrypted SQLite storage in the active demo.

Approval authority is intentionally separated. Admin can analyze and inspect both teams, but cannot impersonate a GRC or SOC reviewer. The backend reloads the saved proposal and expected revision before writing; it does not accept arbitrary browser-supplied risk scores or priorities. Thus, UI filtering is not the security boundary. An unauthorized direct endpoint request is still rejected.

2.4 Social, Cultural, and Political Constraints

For UAE organizations, accountability over business-risk decisions and appropriate handling of security telemetry are relevant requirements. The prototype supports this discussion through explicit owners and auditable reviews, but no organization-specific compliance mapping was completed. English labels and a local demonstration do not establish localization, accessibility or suitability for all users.

If real logs are introduced, the applicability of Federal Decree-Law No. 45 of 2021 concerning personal-data protection must be assessed for the actual organization and data flows (United Arab Emirates, 2021). This report does not provide legal advice or assert compliance. Jurisdiction, exemptions, authorization, retention and cross-border processing must be reviewed before operational collection. A Colab upload that is acceptable for fictional data may be inappropriate for confidential telemetry.

2.5 Ethical and Legal Compliance

The ethical approach is to avoid harm, disclose limitations, protect sensitive information and preserve human responsibility. SGP1 identified ACM/IEEE professional principles and ISO information-security references as relevant guidance (Alsehhi et al., 2026). This report does not turn those references into a completed professional-code audit or ISO certification claim.

The most important reporting obligation is honesty about evidence. Synthetic labels can support software and experimental evaluation, but not claims of proven deployment effectiveness. A classifier that exceeds its false-alarm limit must remain unreleased even when overall accuracy appears high. Table 3 summarizes the safety boundaries. Control membership scores are not measured causal risk reduction, and controller tests are not a completed user-acceptance study.

Table 3: Safety decisions and their assurance boundary

Decision	**Meaning and limitation**
Synthetic sources only	Supports repeatable tests; does not establish representative attack prevalence.
Immutable input evidence	Changes are written to working records, not the original JSON/JSONL.
Separate team approvals	Prevents Admin or the other team from authorizing a different team's mutation.
Shadow ML	Experimental predictions are visible comparisons, not executable risk authority.
Read-only monitor	Shows safe command telemetry; does not expose a shell, keys or review notes.
Local role keys	Suitable for a private lab; not a substitute for production identity/security controls.

Chapter 3

System Design and Integration

3.1 System Modules, Components, and Setup

Figure 1 shows the implemented local architecture. Three source datasets enter a shared preparation function. Integration and validation create enriched event records, after which temporal aggregation produces model sessions. Primary rule assessment and experimental model outputs remain distinguishable. An explicit policy constructs proposed risk/priority changes, and owning-team approval controls the mutable SQLite records.

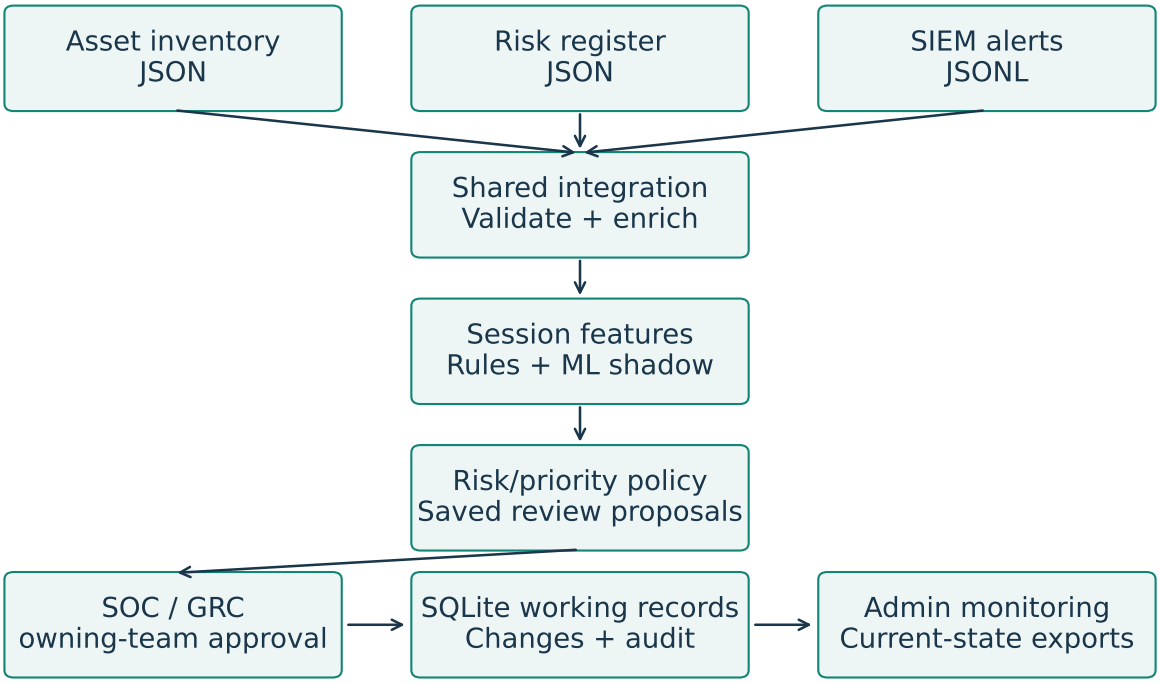


Figure 1: Implemented local architecture; external SIEM/GRC vendor systems are not connected.

The active backend is launched by `demo.py`. It loads the trusted model bundle once, seeds or reopens the working database and serves Admin, SOC and GRC pages on port 8010.

Training is offline and is not repeated when a new inference request arrives. Colab is a training environment, not a requirement for running the examiner demonstration.

3.1.1 Exactly Three Operational Inputs

The source contract is summarized in Table 4. JSON is appropriate here because assets and risks include typed values, historical records and nested control context. JSONL allows alert records to be represented independently. This is a serialization choice, not a claim that JSON improves classifier accuracy or is always faster than CSV. The models ultimately consume tabular, allowlisted features. RFC 8259 provides the underlying JSON interchange specification (Bray, 2017).

Table 4: Operational input contracts and their roles

Input	**Representative fields**	**Purpose**
Asset inventory, JSON	Asset ID, IP/hostname, type, criticality, validity and record times.	Resolve affected business asset and its historical context.
Risk register, JSON	Risk ID, asset ID, category, likelihood, impact, control state, historical times.	Attach registered risk context without multiplying alert rows.
SIEM alerts, JSONL	Event ID/time, affected identity, rule family/level, protocol, account, outcome.	Provide observed technical events for cleaning and sessions.
Offline annotation sidecar	Session/campaign ID, scenario label and reviewed control labels.	Training/evaluation only; excluded from operational preparation and inference.

3.1.2 Integration Before Analytical Cleaning and Features

Raw records first undergo parsing and essential schema checks; an invalid timestamp cannot meaningfully participate in an as-of join. The project requirement to combine sources before analysis is implemented as a shared enriched-event representation before session feature engineering, not as blindly concatenating unrelated tables. Historical context is evaluated at event time. A valid snapshot must satisfy its validity interval and must have been recorded no later than the event being enriched.

Matching uses explicit affected-asset identity and checks destination-IP consistency. If no suitable ID exists, an exact unique destination-IP match or exact hostname match can be used. An attacker's source IP is never treated as the victim asset, and ambiguous/null matches are not guessed. Multiple risks remain nested context rather than creating duplicated event observations. The representative prior-risk pair used for Model 2 comes from one actual registered risk; maximum likelihood and maximum impact from unrelated records are not synthesized into a new pair.

Exact event duplicates are removed deterministically. Conflicting versions of a stable

event ID are excluded, rather than arbitrarily selecting one version. These exclusions are recorded and require review. The same preparation function serves training and inference, reducing the risk of contradictory source-joining behavior across the two paths.

3.1.3 Session Construction and Feature Contract

The current aggregation schema uses a 60-second window. Only completed earlier observed sessions within the supplied batch contribute to the previous-24-hour context; the prototype is not a cross-batch streaming memory service. Table 5 lists the 16 Model 1 features. Asset criticality and current risk values are not scenario-classification predictors, which helps separate event interpretation from business impact.

Table 5: Model 1's complete allowlisted feature set

Feature	**Interpretation**
`event_family`, `primary_protocol`	Categorical event family and protocol.
`event_count`, `duration_seconds`	Session size and elapsed observation span.
`max_rule_level`, `mean_rule_level`	Maximum and mean source rule severity.
`distinct_rules`, `distinct_sources`	Diversity of triggered rules and observed sources.
`distinct_accounts`	Number of distinct associated accounts.
`failed_count`, `success_count`	Authentication outcome counts.
`failure_ratio`	Failed outcomes relative to relevant observed outcomes.
`success_after_failures`	Indicator of a successful outcome following failures.
`max_events_in_10s`	Maximum short-window event burst.
`external_source_fraction`	Fraction attributed to external sources.
`event_rate_per_minute`	Event rate normalized by observation duration.

Feature meaning is constrained by the generator and source contract. In the saved fit partition, external-source fraction has no variation and distinct-source count is constant. These columns therefore do not demonstrate learned discrimination across those conditions. A later representative dataset should specifically test those dimensions rather than assuming the feature names imply validated coverage.

3.1.4 Model 1: Supervised Scenario Classification

Model 1 predicts one of `benign`, `credential_access` or `reconnaissance`. It is a supervised multiclass problem, not clustering, image recognition or a risk-score regression. Logistic regression, random forest and histogram gradient boosting were compared on a separate selection partition. Random forest achieved the highest recorded selection macro-F1 and was retained.

A random forest combines randomized decision trees; the implementation aggregates class probabilities across trees rather than claiming a single deterministic rule (Breiman, 2001;

scikit-learn developers, nda). This is suitable for an experimental tabular baseline, but does not make the model intrinsically explainable or guarantee transfer to real environments. The evidence contains no ANN/CNN comparison and therefore cannot establish superiority over neural architectures.

Preprocessing is fitted on training observations, with categorical encoding and numeric transformation contained in the pipeline. Probability calibration uses disjoint calibration records with the fitted base model frozen; the base is not silently refitted on calibration observations. Threshold selection is performed separately. The runtime accepts the highest-probability class only when its calibrated confidence meets the selected threshold; otherwise it abstains. Confidence concerns the class prediction, not the probability of compromise or business loss (scikit-learn developers, ndc).

Table 6: Training implementation configuration for reproducibility

Component	**Configured settings**
Preprocessing	One-hot categorical encoding, unknown categories ignored; numeric StandardScaler; fit-partition fitting only.
Random-forest candidate	160 trees; maximum depth 12; minimum leaf size 3; balanced-subsample class weights; two workers; seed 42.
Logistic-regression candidate	$C = 1$; maximum 2,500 iterations; balanced class weights; seed 42.
Gradient-boosting candidate	100 iterations; 15 maximum leaf nodes; L2 regularization 1; seed 42.
Calibration	Sigmoid calibration of frozen selected base; disjoint calibration data; no base refit.
Model 1 acceptance	Saved confidence threshold 0.50, selected using only the threshold partition.
Control classifiers	Binary logistic regression, $C = 1$, maximum 2,500 iterations; control-wise thresholding on the threshold partition.

Table 6 records the implementation configuration, not the outcome of a large parameter-optimization study. Probability calibration does not by itself demonstrate good calibration: the saved report contains no reliability-diagram, Brier-score or expected-calibration-error result. Such measurements should be added in future evaluation rather than inferred from the use of a calibration routine.

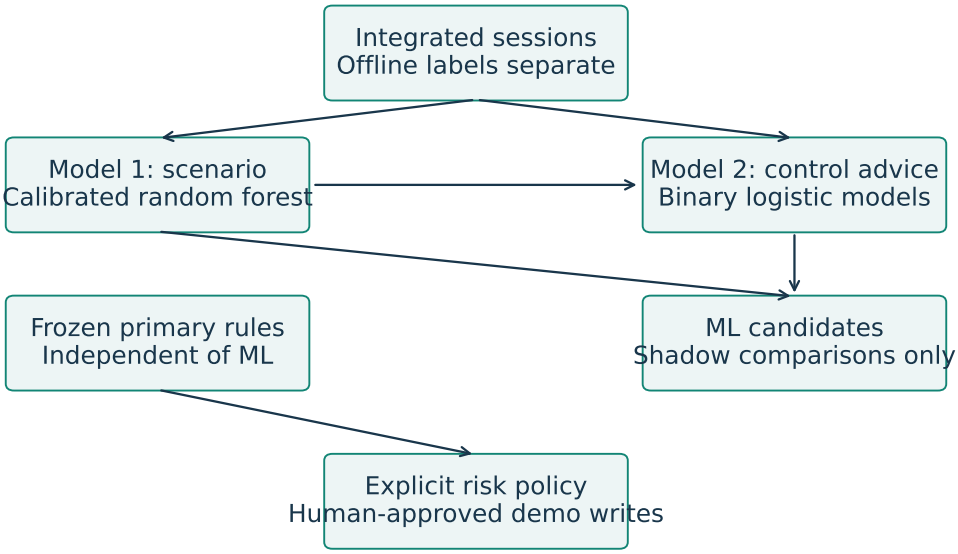


Figure 2: Separate primary-policy authority and two experimental learning tasks. The figure is a conceptual view of the implemented paths, not a benchmark plot.

3.1.5 Partitioning and Leakage Control

The supplied model was trained from 900 synthetic sessions grouped into 60 campaigns. A fixed seed of 42 divides groups into fitting, selection, calibration, threshold and test partitions. Figure 3 shows row counts; no campaign belongs to more than one role. This provides an unseen-synthetic-campaign holdout, not a guarantee of independent organizations, sensor installations or attack families.

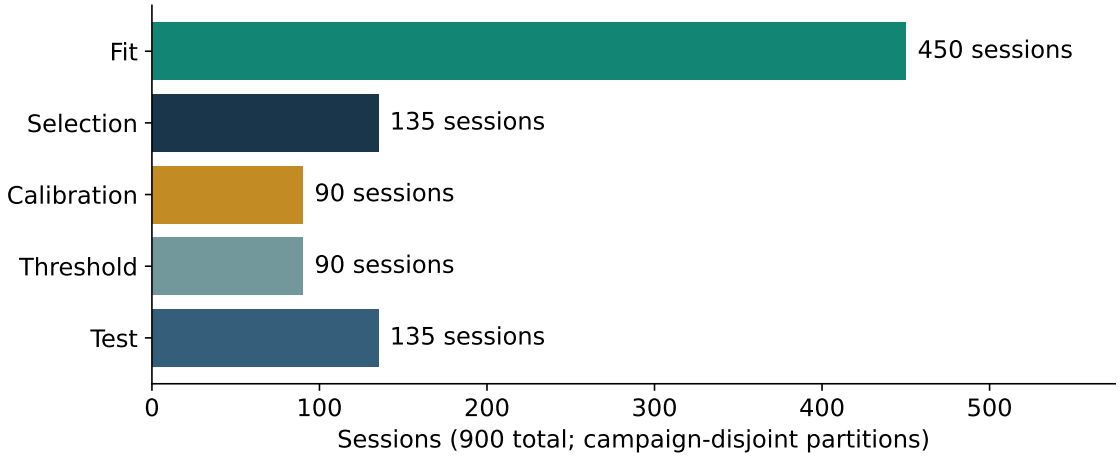


Figure 3: Recorded campaign-disjoint partition sizes. The final test contains 45 sessions per class.

The test set is not used to choose the candidate, calibrate it or select its confidence threshold. This separation matters because tuning any of those choices against the fi-

nal confusion matrix would bias the claimed estimate. Even with group separation, a synthetic generator can share systematic patterns across campaigns. External validity therefore remains substantially weaker than a holdout from independently collected real environments.

3.1.6 Model 2: Supervised Multi-label Control Advice

Model 2 uses binary-relevance logistic regression: one supported classifier predicts membership for each catalogue control, allowing a session to receive several control labels. Its feature set contains the 16 telemetry features plus asset type, predicted scenario, asset criticality, current likelihood, impact and prior similar-session count. The target is the reviewed set of relevant controls, not an attack label automatically copied into a control label.

The recorded control-model fitting pool contains 585 observations from the train and selection partitions. Grouped out-of-fold Model 1 predictions are used for its fitting scenario input, whereas threshold and test rows receive predictions from the frozen Model 1. This avoids using the oracle scenario label as a predictor. It also means Model 1 errors can propagate into control advice, an important reason to evaluate the combined pipeline rather than only isolated classifiers.

For control j, the logistic membership score has the form

$$s_j(x) = \frac{1}{1 + \exp[-(w_j^T z(x) + b_j)]}. \tag{3.1}$$

The saved implementation explicitly treats this as an uncalibrated membership score. It is not a probability that implementing the control will prevent an incident. Controls lacking training or positive test support remain unsupported. Catalogue fallback advice is kept distinguishable from learned membership evidence.

3.2 Technologies and Standards Applied

Table 7 distinguishes the executable stack from SGP1 proposals. The scientific stack is pinned to the saved model's expected environment, notably Python 3.12 and scikit-learn 1.8.0. A joblib file must be treated as executable trusted input: a checksum verifies identity, not that a malicious artifact is safe. No public model-upload endpoint is provided.

Table 7: Actual technologies and deployment boundaries

Component	**Implemented choice**	**Boundary**
Source/model processing	Python, pandas, NumPy, scikit-learn, joblib.	Pinned scientific environment; CPU-only workflow.
Active HTTP service	Standard-library threaded HTTP server.	Loopback demonstration, not an Internet-facing production server.
Working state	SQLite with transactions and revisions.	Local synthetic systems; no external vendor writeback.
User interface	Local HTML, CSS and JavaScript.	Admin, SOC and GRC role views; no Streamlit dependency.
Prepared prototype	Separate FastAPI adapter.	Not the active port-8010 demonstration; HTTP stack not verified here.
Exchange formats	JSON and JSONL; finite typed values.	No claim of native raw vendor-export compatibility.
Professional references	NIST CSF and SGP1 security/ethics guidance.	Not a certified control or compliance implementation.

3.3 Challenges and Solutions

Table 8 explicitly reconciles SGP1 with the observed SGP2 implementation. No change in technology is treated as failure solely because it differs from the plan; the issue is whether the delivered choice satisfies a measurable objective. Conversely, an implemented local substitute cannot be described as completion of a live external requirement.

Table 8: SGP1-to-SGP2 requirement and design traceability

SGP1 reference	**Planned capability**	**SGP2 evidence / status**
FR1.1–1.4	Read/write SIEM and GRC through APIs.	Local three-source inputs and synthetic-system writes demonstrated; vendor connectors future work.
FR2.1–2.4	Normalize and link alerts, assets and risks.	Shared deterministic integration and historical enrichment implemented.
FR2.5	AI matching when direct matching fails.	Intentionally not implemented; unresolved identities are excluded for review.
FR3.3–3.4	User-adjustable risk formula and weights.	Versioned explicit policy; unrestricted user tuning not implemented.
FR4.3–4.5	Confidence, feedback learning and fallback.	Shadow confidence and primary rules implemented; automatic feedback retraining not established.
FR5, FR6	Dashboard, history and roles.	Local queue/register, exports, reviews, audit and role checks implemented; notifications future work.
NFR1	Alerts processed within two seconds.	No controlled latency benchmark; target not verified.
NFR2, NFR5	Encryption and 24/7 operation.	Loopback lab safeguards only; encryption and availability targets not demonstrated.
Architecture	Streamlit, Wazuh/Elasticsearch, JWT roles.	HTML/JS and separate lab keys in the active demo; no verified live sensor or JWT deployment.

Chapter 4

Implementation, Testing, and Results Analysis

4.1 Implementation Summary

The implementation progresses beyond SGP1's conceptual prototype by making the effects of approvals observable in persistent records. The source files remain immutable evidence. Enriched sessions produce saved cases and proposed changes. Current-state risk and alert tables are separate mutable records. A review submits only the saved proposal identifier, decision and reason; the backend retrieves the authoritative before/after values itself.

Risk scoring remains an explicit project policy, not an ML estimate:

$$R = \frac{L \times I}{25}, \qquad L, I \in \{1, 2, 3, 4, 5\}. \tag{4.1}$$

For the registered risk uniquely matched to strong credential or reconnaissance evidence, the policy can propose $L' = \min(5, L + 1)$ while preserving impact. This should be interpreted as a reviewable ordinal-policy adjustment, not a calibrated probability update. Ambiguous or unmapped risk categories require review; the system does not invent an unrelated risk to fill a gap.

The technical severity band is derived from source rule level scaled to a ten-point range and combined with an asset-criticality band through the configured priority policy. Routine benign activity is not escalated simply because the asset is important. Thresholds and the combination matrix belong to the versioned engineering policy; the report does not describe them as a universal risk-management standard.

4.1.1 Approval State and Active Writeback

Analysis does not approve its own outputs. A pending GRC proposal is authorized only by GRC and a SOC proposal only by SOC. Within the write transaction, expected record revisions are compared with current revisions. A stale group update is rejected atomically, preventing a partially reprioritized alert group. A repeated decision is idempotent rather

than applying the same likelihood increase twice.

After one risk update, other proposals based on the same old risk revision become stale. This prevents repeated increases from the same evidence batch. Starting a new rehearsal creates isolated seeded working records while preserving prior exercises and audit history. These controls make the demonstration reproducible without deleting the underlying evidence or earlier decisions.

4.2 Testing Strategy and Process

Testing combines unit, integration, actual loopback HTTP and frontend-controller regression checks. Pure source-contract tests validate schemas and transformations. Core tests exercise policy and persistence using the actual trusted model bundle. HTTP tests run the local server and submit real commands with synthetic role credentials. Controller tests execute the actual JavaScript against deliberate DOM/API doubles; these are not browser-render or usability tests.

Table 9: Executed verification suites and their evidential meaning

Suite	**Passed**	**What it establishes**
Original model/integration tests	79	Feature contracts, grouped training and source integration.
Shared backend-core tests	33	Bounded execution, policy separation and trusted-model behavior.
Active demo core tests	32	Approval writes, revisions, stale checks and persistence.
Active demo HTTP tests	29	Actual request authorization, updates, exports and live monitor access.
Activity-unit tests	4	Bounded, read-only, safe process telemetry.
Total Python regressions	177	Software checks on supplied fixtures; not a detection-accuracy estimate.
Frontend controller scenarios	20	Role-only loading, failure handling, compatibility and monitor behavior.

The counts in Table 9 describe different assurance dimensions. A passed HTTP test does not add a correctly classified attack to the ML test set. Likewise, 100% test completion is not 100% real-world detection accuracy. The earlier FastAPI HTTP tests were not included because the required web dependencies were unavailable in the evaluation environment.

4.2.1 Metric Definitions

For class c, precision is $TP_c/(TP_c + FP_c)$ and recall is $TP_c/(TP_c + FN_c)$. Their harmonic mean is

$$F1_c = \frac{2P_cR_c}{P_c + R_c}, \qquad F1_{macro} = \frac{1}{3}\sum_c F1_c. \tag{4.2}$$

Accuracy over all sessions is correct accepted predictions divided by all test sessions. Coverage is the accepted fraction. Accepted-only accuracy conditions on non-abstention and must not be confused with accuracy over all inputs. The implementation counts abstentions as missed true classes in recall/F1, rather than removing difficult cases (scikit-learn developers, ndb).

The benign false-positive rate is the proportion of benign sessions assigned an attack class. Abstentions are excluded from its numerator, so FPR must always be interpreted with coverage. Model 2 micro precision/recall/F1 pool control-label decisions, while exact-set accuracy requires the entire predicted control set to match. Hamming loss divides all incorrect binary control decisions by the number of sessions times catalogue labels. These definitions explain why sparse-label results can appear strong even when control coverage is narrow.

4.3 Results and Analysis

4.3.1 Dataset Provenance and Cleaning Results

Table 10 compares two synthetic datasets serving different purposes. The training corpus contains 900 sessions with scenario/control annotation sidecars. The examiner corpus is a separate fictional operational batch with no new independent accuracy labels. It demonstrates source-quality handling and active workflow behavior; running it through a model does not produce a new validated accuracy figure.

Table 10: Training and examiner-demonstration corpus sizes

Quantity	**Training sample**	**Active demo**
Unique assets	60	30
Asset snapshots	120	36
Unique registered risks	120	60
Risk snapshots	240	72
Raw alert rows	26,086	2,367
Matched working/event rows	26,071	2,355
Prepared activity sessions	900	132
Labeled held-out test sessions	135	Not supplied

Table 11 accounts for the active queue size. Cleaning and matching remove 12 raw rows from the working-alert representation. They are not twelve known false alarms:

the exclusions concern data quality and identity, not ground-truth maliciousness. Six historical normal sessions are included in the demo sources, but this does not establish representative operational prevalence.

Table 11: Active demonstration alert-row accounting

Stage or exclusion	**Rows**
Raw SIEM input	2,367
Exact duplicate rows removed	6
Invalid timestamp excluded	1
Both conflicting versions of an event ID excluded	2
Unresolved asset rows excluded	3
Matched unique working alerts	2,355

4.3.2 Model 1: Held-out Performance

The test partition contains 135 synthetic sessions, with 45 for each true class. Table 12 reports the full per-class results. Model 1 correctly classifies 127 sessions: $38 + 45 + 44 = 127$, giving $127/135 = 94.07\%$. Its confidence threshold is 0.50 and no test observation abstains, so coverage and accepted-only accuracy do not hide a rejected subset in this run.

Table 12: Model 1 class-wise results on 135 held-out synthetic sessions

Class	**Precision**	**Recall**	**F1**	**Support**
Benign	0.9744	0.8444	0.9048	45
Credential access	1.0000	1.0000	1.0000	45
Reconnaissance	0.8627	0.9778	0.9167	45
Macro average	0.9457	0.9407	0.9405	135

Figure 4 shows where the errors occur. Seven benign sessions are mistaken for reconnaissance, and one reconnaissance session is labeled benign. Credential-access performance is perfect only on these 45 synthetic test examples. It must not be described as perfect detection of arbitrary credential attacks.

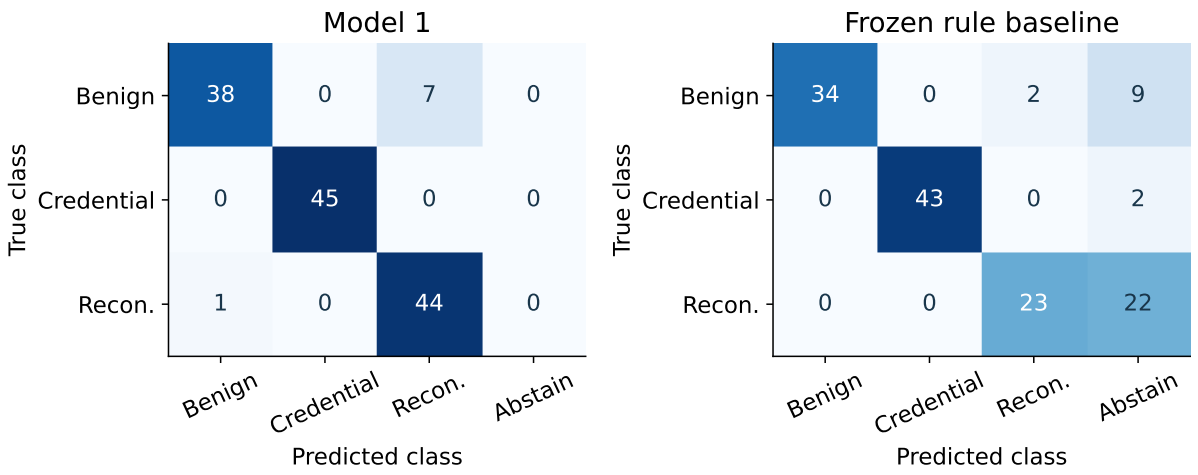


Figure 4: Recorded confusion matrices. Rows are true classes; columns are predictions. The baseline abstains on 33 sessions.

4.3.3 Model Selection and Comparison with Primary Rules

The selection scores in Table 13 are not test results and should not be mixed with the final evaluation. Random forest leads on the selection partition, but an exhaustive hyperparameter study, neural-network comparison and external dataset evaluation were not performed.

Table 13: Recorded selection-partition candidate macro-F1 scores

Candidate family	**Selection macro-F1**
Logistic regression	0.9333
Random forest (selected)	0.9478
Histogram gradient boosting	0.9259

Figure 5 and Table 14 compare the selected model with the frozen rules on the same test observations. Model 1 improves macro-F1 by 0.1088, but its benign FPR is worse. The rules accept 102 of 135 sessions and correctly classify 100, yielding 98.04% accepted-only accuracy but only 74.07% accuracy over all sessions. Comparing 94.07% ML accuracy only to the rules' accepted-only figure would therefore be misleading.

Table 14: Model 1 and frozen-rule test results with common metric definitions

Metric	**Model 1**	**Rules**
Accuracy, all test sessions	94.07%	74.07%
Macro-F1	0.9405	0.8317
Coverage	100.00%	75.56%
Accepted-only accuracy	94.07%	98.04%
Benign false alarms / support	7/45	2/45
Benign false-positive rate	15.56%	4.44%

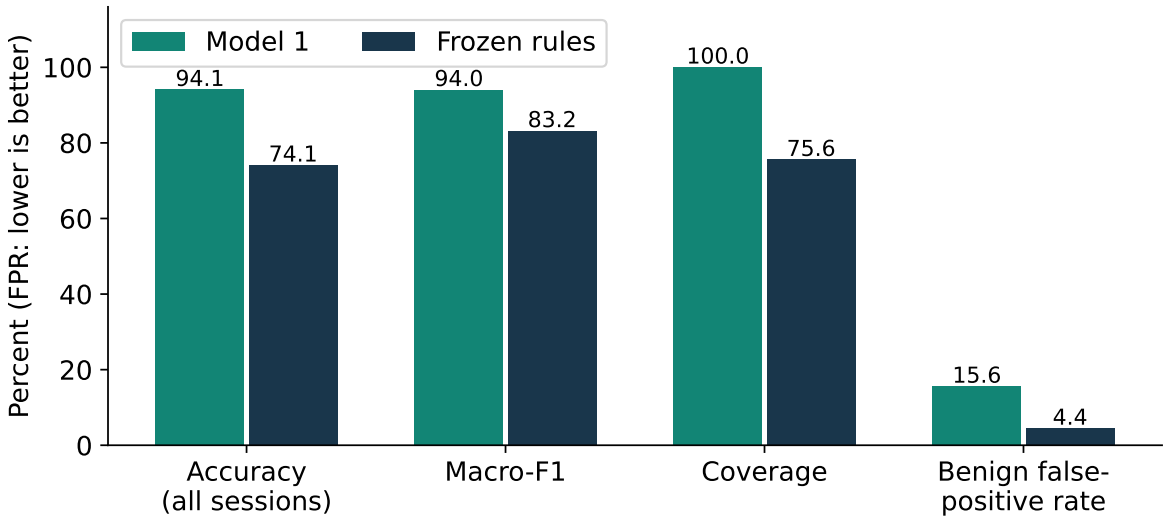


Figure 5: Coverage and error trade-offs on the same synthetic test set. A higher false-positive rate is worse.

4.3.4 Threshold Selection and Release Decision

Figure 6 plots the saved threshold-search observations from the separate 90-session threshold partition. This is not a ROC curve, a training loss curve or a measurement taken on the test set. The chosen threshold reflects the implementation's selection procedure; failure to satisfy every gate does not authorize choosing a new threshold after inspecting final test results.

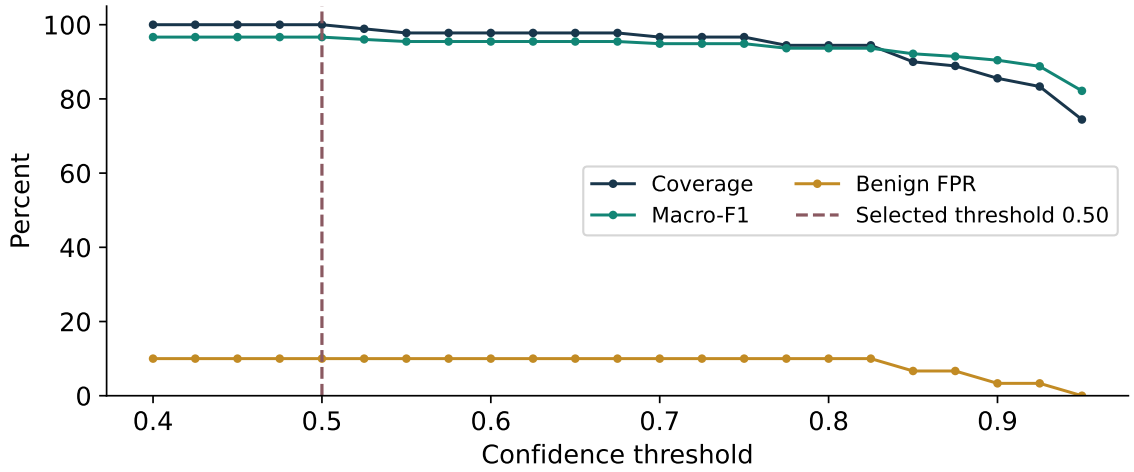


Figure 6: Saved threshold-partition search; the final test remains held out.

On the held-out test, the FPR point estimate is 15.56%. Its recorded 95% Wilson interval is 7.75–28.78%, emphasizing the limited benign sample size. The interval is not a campaign-cluster-adjusted confidence bound and should be read as descriptive binomial uncertainty. The 5% engineering limit fails, and real reviewed cyber-range data are also absent. Both ML components remain unreleased shadow candidates despite passing

several numerical checks.

Table 15: Model 1 release-gate assessment

Engineering check	**Observed evidence**	**Result**
Macro-F1 at least 0.80	0.9405	Pass
Each attack-class recall at least 0.75	1.0000 and 0.9778	Pass
Benign FPR at most 0.05	0.1556	Fail
Coverage at least 0.80	1.0000	Pass
F1 improvement over rules at least 0.05	0.1088	Pass
At least 10 test sessions per class	45 per class	Pass
Real reviewed cyber-range data	Synthetic only	Fail
Operational/advisory release	Full eligibility not met	Blocked

The gate values in Table 15 are project engineering criteria. They are not mandated thresholds from NIST, ISO or a regulator. The rules are retained as primary assessment, but their own error and coverage limitations also prevent any claim that they are operationally validated.

4.3.5 Model 2: Control-Recommendation Results

Model 2's micro precision, recall and F1 are all 0.9542. Exact-set accuracy is 0.9037, while Hamming loss is 0.00543. Table 16 compares these with the recorded scenario-frequency baseline. The baseline is derived from fitting data rather than test-label frequencies. These are relevance-label agreement metrics, not measurements of whether recommended controls reduce successful attacks.

Table 16: Model 2 held-out synthetic label-agreement metrics

Metric	**Model 2**	**Scenario baseline**
Micro precision	0.9542	0.8861
Micro recall	0.9542	0.8750
Micro-F1	0.9542	0.8805
Macro-F1 over all 30 controls	0.1905	0.1555
Exact-set accuracy	0.9037	0.6519
Hamming loss (lower is better)	0.00543	0.01407

Only six catalogue controls have positive test support, listed in Table 17 and illustrated in Figure 7. The low all-catalogue macro-F1 reflects zero-valued scores for unsupported labels under the recorded metric convention. Those zeros are not measurements that the system tried and failed to recommend 24 adequately tested controls. Sparse negatives can also make Hamming loss look small, so it must be interpreted alongside support.

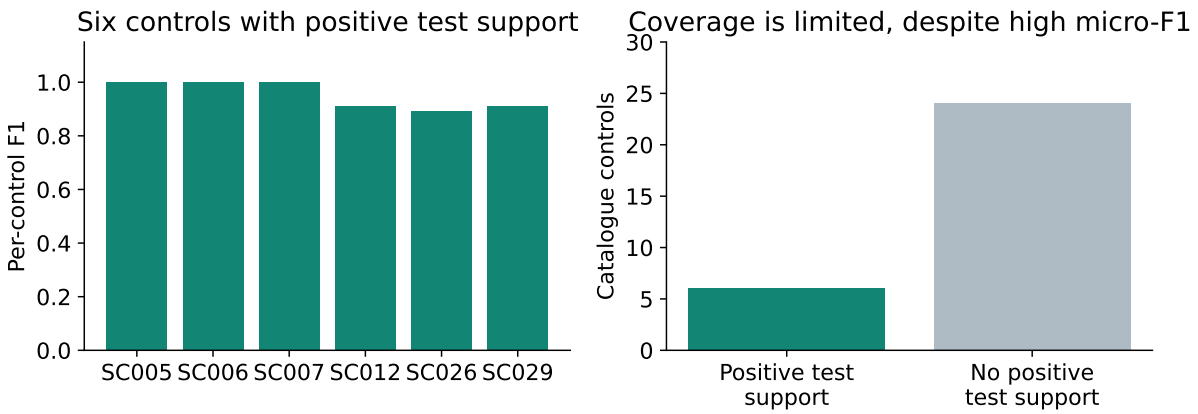


Figure 7: Supported-control F1 and catalogue coverage. High micro-F1 does not establish coverage of all controls.

Table 17: Controls with positive held-out support

Control ID	Positive test support	Precision / recall	F1
SC005	45	1.0000 / 1.0000	1.0000
SC006	32	1.0000 / 1.0000	1.0000
SC007	45	1.0000 / 1.0000	1.0000
SC012	45	0.9111 / 0.9111	0.9111
SC026	28	0.8929 / 0.8929	0.8929
SC029	45	0.9111 / 0.9111	0.9111

Model 2's proposed numerical control gate passes, but overall release eligibility remains false. Its scenario input depends on Model 1 and its evidence remains synthetic. Neither a membership score nor an implemented control-state label supports a causal estimate of risk reduction. The UI must therefore show control advice as advice, not as an executed mitigation.

4.3.6 Active Demonstration and Before/After Results

In a fresh exercise, analysis generates 132 saved cases, 123 SOC proposals and 63 GRC proposals. Counts are proposals, not approvals or independent unique risks; multiple cases can refer to the same registered risk. The reproducible identity-server example uses session `SES-65f5edbf869d111d265c`. Figure 8 and Table 18 show the actual change contract.

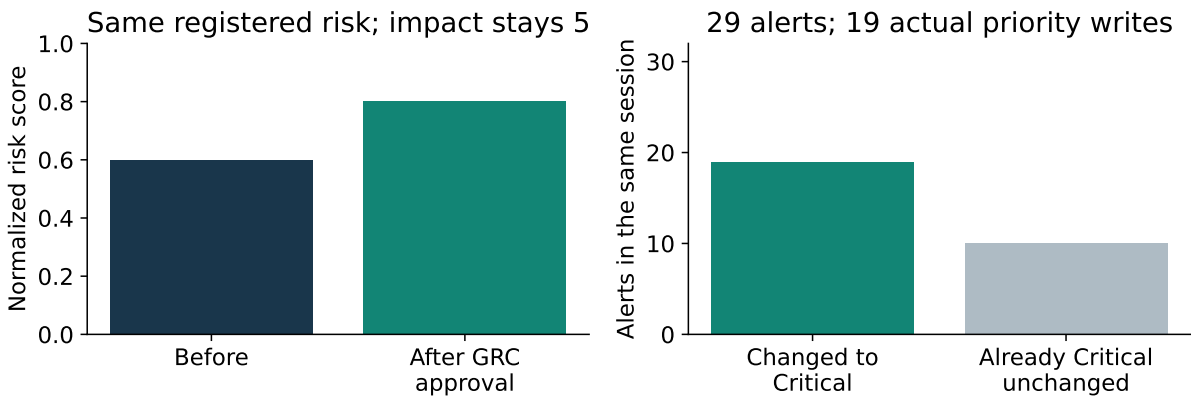


Figure 8: Deterministic policy-and-approval demonstration on fictional working records; these are not ML accuracy results.

Table 18: Persistent changes after owning-team approval

Record or attribute	**Before**	**After**	**Owner**
Risk `DEMO-R001-1` likelihood	3	4	GRC
Same risk impact	5	5	GRC
Normalized risk score	0.60	0.80	GRC
Risk revision	1	2	GRC
Lower-priority alerts in selected session	19	Critical	SOC
Already-Critical alerts in same session	10	Unchanged	SOC

The 0.20 score increase follows Equation 4.1: $3\times5/25 = 0.60$ and $4\times5/25 = 0.80$. It is not a model's probability of attack. Likewise, the 19 priority writes reflect the explicit policy and approval, not a classifier "correctness" count. A download reads current database values; restarting the server preserves them. The original source files intentionally retain their original bytes.

4.3.7 Interface Failures, Corrections and Observability

User reports revealed interface assumptions that were not captured by the earliest controller fixtures. A valid SOC key could authenticate and then fail because an unfiltered page contained a GRC panel; the controller used panel existence to decide to fetch the risk endpoint. A GRC proposal could fail when optional control advice used an older response shape. Table 19 records these issues as evidence of test-driven correction, not as an assertion that every user environment is now verified.

Table 19: Observed interface problems and regression coverage

Observed issue	**Cause / corrective decision**	**Regression**
Literal template labels	Raw source could be served without substitution; readable defaults and server headings added.	Raw-source and served-page checks.
SOC receives ADMIN OR GRC error	Table reads based on panel existence; changed to authenticated-role selection.	Unfiltered markup tested for all three roles.
GRC undefined `length`	Optional list or legacy nested advice absent from expected field.	Six legacy/missing/null/malformed cases.
Admin needs backend visibility	Only final state was obvious; added safe request-start/outcome feed.	Concurrent HTTP, role denial, redaction and busy-poll checks.

The backend activity card is a read-only process-local view of actual authenticated commands. It reports starts, completion/failure, elapsed time and allowlisted numeric outcome fields, including record writes. It is not an operating-system terminal and does not fabricate per-step ML progress. The most recent 250 events reset on server restart; the database audit remains persistent. Keys, raw command bodies and review notes are excluded.

4.4 Potential Improvements

The highest-priority next step is representative authorized data collection with independent scenario and control reviews. Benign diversity must increase before attempting to reduce false alarms by tuning. Grouped validation should be extended across collection campaigns, generators, organizations and time periods. More control labels require positive and negative support, not simply additional unannotated alerts.

Live vendor connectors need schema adapters, stable identifiers, idempotency, delivery confirmation, retry handling and reconciliation after partial external failures. These concerns are not solved by replacing a local URL with a vendor URL. An organization also requires individual identities, protected secrets, encrypted transport/storage as applicable, backups and permission reviews.

No two-second latency, 24/7 availability, workload reduction, cost saving or usability improvement is established by the current evidence. Future performance tests should report batch size, hardware, warm/cold state, concurrent users, latency percentiles and failure rates. A formal usability study should include SOC and GRC participants using realistic tasks. These additions should be evaluated separately from classifier metrics rather than collapsed into one “system accuracy” percentage.

Chapter 5

Project Management and Teamwork Reflection

SGP1 documents a five-person team and a planned division of research, requirements, interface and design work (Alsehhi et al., 2026). That history can explain the starting organization, but it does not establish the actual percentage of SGP2 implementation work completed by each member. The source and interaction history establish an iterative development process; they do not provide signed timesheets or an agreed semester task ledger.

5.1 Tasks And Schedule Gantt Chart

Figure 9 is an explicitly proposed relative sequence for organizing implementation and final validation. It is not presented as the actual completion calendar. Actual dates require team confirmation, particularly because SGP1 and the supplied SGP2 template both say Spring 2026 whereas the saved model training timestamp is 25 October 2026.

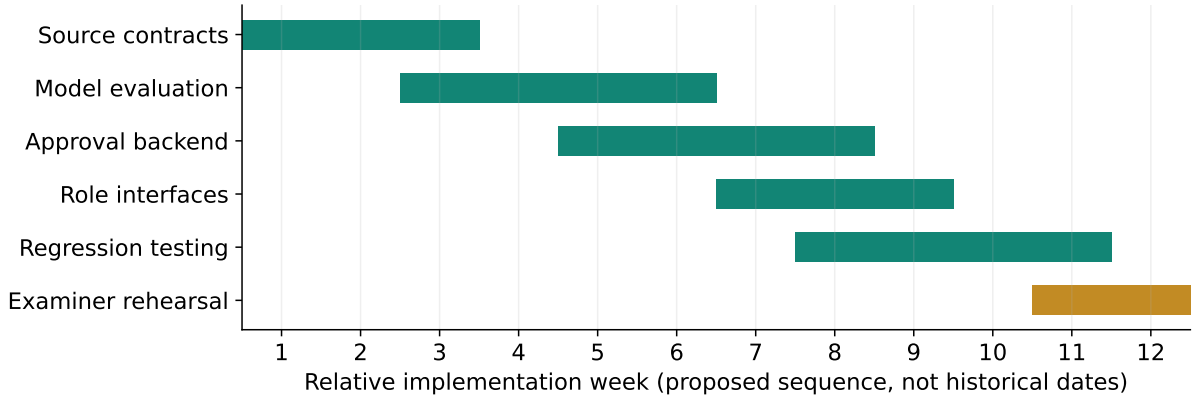


Figure 9: Proposed relative work sequence for planning/reconciliation; bars are not historical completion evidence.

The dependencies are substantive: source contracts precede meaningful training; grouped

evaluation precedes release decisions; backend approval semantics precede claims of an active interface; and whole-workflow regression tests precede an examiner rehearsal. The observed role-loading and optional-data errors demonstrate why a locally passing component should not immediately be treated as a complete end-user success.

5.2 Resources used During the Project

The verified resources include development computers, Python scientific libraries, SQLite, the repository, Colab output, synthetic datasets and the SGP1 report. Dedicated sensors, commercial GRC access and real-company logs are not evidenced for this implementation. The team should record the presentation laptop's CPU, RAM and operating system during rehearsal. Table 20 distinguishes documented SGP1 roles from SGP2 confirmation needs.

Table 20: Documented SGP1 responsibility and SGP2 confirmation status

Student	**SGP1 documented focus**	**SGP2 reporting boundary**
Taher Mousa	Requirements lead, interoperability, initial prototype and reporting.	Actual implementation tasks and percentages require team approval.
Ahmed Aref Alsehhi	AI/ML research, non-functional requirements and documentation.	Do not infer actual SGP2 ML ownership from SGP1 plans.
Abdulla Alattas	SOC/SIEM research, system requirements and physical design.	Confirm any live collection or infrastructure work separately.
Abdulrahman Bin Braik	GRC/ISO research, functional requirements and GUI design.	Confirm final interface and governance contributions.
Abdulaziz Al Rabeei	SOC/SIEM and AI research, logical design and reporting.	Confirm implementation and evaluation contributions.

The main management lesson is to separate demonstration scope from intended deployment. A stable fictional-data demonstration with transparent limits is more defensible than an undocumented claim of live integration. Another lesson is to minimize incompatible partial updates: HTML, controller, server and response contracts must be versioned together. User feedback on role scope and login errors should be converted into reproducible tests rather than answered only by redesigning the page.

The team should retain a release checklist linking the chosen commit, model checksum, dataset manifest, test results and examiner script. A known model release failure must remain in the checklist even when it complicates the presentation. This supports technical accountability and allows future team members to reproduce both successful and unsuccessful results.

Chapter 6

Conclusion and Future Recommendations

IRIS implements an accountable local connection between SIEM-derived event evidence, affected assets and registered business risks. The most important SGP2 achievement is the complete evidence-to-proposal-to-approval chain with visible persistent effects. Data integration, source-quality checks, separate team authority, optimistic revisions and audit/export evidence are implemented rather than represented only by conceptual diagrams.

The two supervised models demonstrate a repeatable experimental pipeline. Model 1's 94.07% synthetic-test accuracy and 0.9405 macro-F1 coexist with an unacceptable 15.56% benign false-positive rate. Model 2's 0.9542 micro-F1 coexists with positive held-out support for only six controls. Neither component qualifies for operational release. These are useful research findings because they identify the concrete limits of the available data and show that a release gate can prevent optimistic misuse of an aggregate score.

The prototype does not demonstrate production SIEM/GRC connectivity, real-data effectiveness, enterprise identity, encryption, high availability or a two-second performance guarantee. The use of deterministic primary policy and explicit approvals is a deliberate safety boundary, not evidence that the rules are already suitable for every organization.

Future work should first obtain authorized, diverse and independently reviewed data; then evaluate across time and collection environments; then add reliable vendor delivery and enterprise controls. Only after those steps should the team consider changing the role of ML in the decision process. The final examiner presentation should emphasize what actually changes in the backend, who approves it, and how the evidence can be reproduced, while openly explaining what remains experimental.

Chapter 7

Statement of Contribution

The supplied SGP1 report provides earlier contribution percentages, but these must not be copied into SGP2 as if they describe new implementation work. Table 21 records the SGP2 task structure without inventing individual weights. The five values in each task row must sum to 100% after team agreement. "TBC" means *to be confirmed*, not zero contribution. Students must sign Table 22 themselves.

Table 21: SGP2 task contribution percentages awaiting team confirmation

Task	**Ahmed**	**Taher**	**Abdulla**	**Abdulr.**	**Abdulaziz**
Source integration and validation	TBC	TBC	TBC	TBC	TBC
Model training and evaluation	TBC	TBC	TBC	TBC	TBC
Backend policy and approvals	TBC	TBC	TBC	TBC	TBC
Interfaces and demonstration	TBC	TBC	TBC	TBC	TBC
Testing, report and presentation	TBC	TBC	TBC	TBC	TBC

Table 22: Student identification and signatures

Student ID	**Student Name**	**Signature**
202110388	Ahmed Aref Alsehhi	
700041185	Taher Mousa	
202102869	Abdulla Alattas	
700042473	Abdulrahman Bin Braik	
700042076	Abdulaziz Al Rabeei	

References

Alsehhi, A. A., Mousa, T., Alattas, A., Bin Braik, A., and Al Rabeei, A. (2026). Integrated risk intelligence system (iris): Senior graduation project i final project report. Technical report, College of Information Technology, United Arab Emirates University. Spring 2026. User-supplied project report; internal primary source.

Bray, T. (2017). The javascript object notation (json) data interchange format. Technical Report RFC 8259, Internet Engineering Task Force. https://www.rfc-editor.org/rfc/rfc8259.

Breiman, L. (2001). Random forests. *Machine Learning*, 45:5–32. https://doi.org/10.1023/A:1010933404324.

National Institute of Standards and Technology (2024). The nist cybersecurity framework (csf) 2.0. Technical Report CSWP 29, NIST. https://doi.org/10.6028/NIST.CSWP.29.

scikit-learn developers (n.d.a). *Ensembles: Gradient boosting, random forests, bagging, voting, stacking*. Version 1.8.0 documentation. Accessed 27 October 2026. https://scikit-learn.org/1.8/modules/ensemble.html.

scikit-learn developers (n.d.b). *Metrics and scoring: quantifying the quality of predictions*. Version 1.8.0 documentation. Accessed 27 October 2026. https://scikit-learn.org/1.8/modules/model_evaluation.html.

scikit-learn developers (n.d.c). *Probability calibration*. Version 1.8.0 documentation. Accessed 27 October 2026. https://scikit-learn.org/1.8/modules/calibration.html.

United Arab Emirates (2021). Federal decree-law no. 45 of 2021 concerning the protection of personal data. UAE Legislation. Official legislation portal; legal applicability requires organization-specific review. https://uaelegislation.gov.ae/en/legislations/1972.

Appendix A

Reproducibility and Evidence Register

The statistical results in Chapter 4 come from the supplied Colab artifact, not from retraining during report preparation. Table 23 identifies the primary project sources. Figures are regenerated by `make_figures.py` from saved metadata and threshold-search files. No learning curve, importance ranking, ROC/AUC value or latency distribution is fabricated where none was recorded.

Table 23: Primary project evidence used in this report

Evidence	**Location / purpose**
SGP1 report	User-supplied `3.pdf`; requirements, design plans, roles and chronology.
Model results	`artifacts/user_colab_run/models/metadata.json`; selection, split, metrics, support and gates.
Threshold search	`artifacts/user_colab_run/models/threshold_search.json`; threshold-partition observations.
Source integration	`IRIS_Models_v2/iris_models/three_sources.py`; matching and historical context.
Risk policy	`backend/policy.py`; explicit priority and risk proposal logic.
Active approval state	`demo_app/engine.py`; working records, revisions and reviews.
Monitoring/interface	`demo_app/activity.py`, `server.py`, local static assets.
Regression record	`demo/VERIFICATION.md`, test suites and controller scenarios.

The trusted Colab model SHA-256 is

`12e76f280bcaa4854e9f08df9ea05839ea43cbb7691a7d44bfbd9d473eb39950`.

The inspected implementation reference is GitHub commit

`988af097bdd6ecb19335e603d954793f9fc6a5cd`.

Record the presentation's source revision, model and dataset manifest before rehearsing. The identifiers above describe inspected evidence, not every later working copy.

Appendix B

Submission Confirmation Checklist

Before submission, confirm the correct SGP2 semester/date with the advisor; the supplied template and SGP1 both state Spring 2026, whereas the model evidence is dated October 2026. Agree on SGP2 contribution percentages and collect all five signatures. The report deliberately leaves those entries unasserted.

Run the full demonstration on the presentation laptop, recording hardware and environment versions. Verify all three role pages, approvals, downloads and the Admin activity window in a real browser. These checks remain necessary because this report's controller tests are not visual browser tests. If screenshots are added, they must show actual successful execution and be labeled with the corresponding exercise state.

Obtain permission before sharing the private repository, SGP1 report or model bundle outside the assessment team. Confirm that every claim of a live connector, collected dataset or benchmark has direct evidence before adding it. If new measurements are made, update the results tables and retain the measurement method; do not merely replace a number in the executive summary.

The supplied LaTeX is ready for Overleaf using pdfLaTeX and BibTeX. The template's instructional text, dummy example table/figure, undefined sample citations and unclosed color group have been removed or corrected. The CIT logo was reused from the team's own SGP1 report, not redrawn as a new official mark.

Verification Commands

```
python -m unittest demo_app.tests.test_demo -q
python -m unittest demo_app.tests.test_activity -q
python -m unittest backend.tests.test_core -q
node demo_app/tests/test_ui_controller.js
# Run in IRIS_Models_v2:
python -m unittest discover -s tests -q
```